

Strengthening IoT Security

A Hybrid LLM + Machine Learning Framework for
Malware Detection and Vulnerability Assessment

Based on findings from: Jamshidi et al., Internet of Things, vol. 34, p. 101735, 2025

37

Papers Reviewed

2015–2025

Publication Range

Hybrid

Proposed Solution

Finding 1 — IoT Devices Are Under-Defended Targets

Always-On Attack Surface

Low-power devices in smart cities, healthcare, and industrial systems stay connected 24/7 but cannot run antivirus or complex encryption at scale.

Polymorphic Malware

Signature-based detection fails against malware that mutates its code with every spread, making traditional pattern-matching tools obsolete.

Real Consequences

Compromised IoT devices enable data theft, botnet recruitment, system takeover, and physical harm in critical infrastructure.

The paper found that traditional security tools were not designed for IoT — they are too heavy, too slow, and too rigid for resource-constrained devices.

Finding 2 — Traditional ML: Strong Baseline, Clear Ceiling

99.9%

F1-score on 5G-NIDD
(XGBoost / Random Forest)

~98%

Accuracy on CICIDS2018

Models Reviewed

Random Forest · XGBoost · SVM · CNN

Strengths

- Fast inference speed
- Small model footprint
- Reliable on known attack types

Limitations

- Fails on zero-day and polymorphic attacks
- Requires heavy feature engineering
- No contextual understanding of threats

Paper finding: ML models hit a hard ceiling against novel and evolving threats despite excellent performance on structured datasets.

Finding 3 — LLMs Are Powerful but Edge-Impractical Alone

98.2%

SecurityBERT
16.7MB · 0.15s

98.6%

GPT on IoT-23
real malware traffic

95.3%

BERT accuracy
beats GPT-2

1.5×

Slower inference
than ML models

Why LLMs Cannot Work Alone on IoT

Too Large for Edge Hardware

BERT-class models need significant memory impractical on Raspberry Pi-scale devices without modification.

High Inference Latency

GPT runs 1.5× slower than ML, creating bottlenecks when screening high-volume IoT traffic in real time.

Lab-Only Testing

Most reviewed LLM studies ran in simulated environments, raising concerns about live-network performance.

Adversarial Vulnerabilities

Prompt injection and model poisoning remain unsolved security risks in LLM-based detectors.

Finding 4 — The Research Gap No One Has Closed

Some hybrid attempts exist — but all fall short:

HuntGPT

Random Forest + GPT-3.5 for detection with explainability
no complete IoT pipeline.

FedCLLM

Federated learning + LLM client selection privacy-focused
but limited in scope.

EdgeShard

50% latency reduction for LLM inference on edge
addresses speed, not detection.

The Gap

No existing work proposes a complete, end-to-end hybrid pipeline specifically for IoT malware detection AND vulnerability assessment that is fast enough for real traffic, intelligent enough for novel threats, and small enough for edge hardware.

This is the gap HybridShield is built to fill.

Introducing HybridShield

A two-stage framework that combines ML speed with LLM intelligence — built for the IoT edge.

Speed

ML handles ~80% of traffic instantly at low compute cost

Intelligence

LLM catches novel and zero-day threats ML would miss

Feasibility

Quantized to run on Raspberry Pi 4 edge hardware

HybridShield — Two-Stage Pipeline

STAGE 1 — ML Filter

Random Forest / XGBoost

- Screens all incoming network traffic
- Instantly clears benign packets
- Flags ambiguous traffic for Stage 2
- Only 20–30% of traffic escalates
- Keeps LLM invocations minimal



STAGE 2 — LLM Analysis

Quantized BERT + RAG

- Deep analysis of flagged traffic only
- Detects novel malware and zero-days
- RAG pulls live CVE vulnerability data
- 8-bit quantization: 63% size reduction
- Generates human-readable threat reports

Implementation — Tools and Datasets

Tools and Technologies

Scikit-learn

Stage 1 Random Forest / XGBoost

HuggingFace

Stage 2 BERT fine-tuning

BitsAndBytes

8-bit quantization for edge deployment

LangChain + FAISS

RAG pipeline for CVE lookups

MQTT Protocol

IoT device communication simulation

Raspberry Pi 4

Target edge deployment hardware

Datasets

UNSW-NB15

Training Stage 1 on known attack types

IoT-23

LLM fine-tuning on real IoT malware traffic

N-BalIoT

Botnet behavior patterns

TON-IoT

End-to-end pipeline testing

Performance Evaluation



HybridShield vs. Other Approaches

Metric	ML Only	LLM Only	HybridShield
Novel Threat Detection	Low	High	High
Inference Speed	Fast	Slow	Fast
Model Size	Small	Large	Small (quant.)
Edge Deployable	Yes	No	Yes
False Positive Rate	Medium	High	Low

Conclusion

01

Traditional ML hits a ceiling

Up to 99.9% on known threats but completely blind to new and evolving malware.

02

LLMs close the gap but at a cost

Contextual intelligence and novel-threat detection at the expense of speed and edge feasibility.

03

HybridShield proposition

ML filters 70–80% of traffic, LLM handles what ML cannot. Edge-deployable through quantization.

04

Future Work

Test on live IoT networks, harden against adversarial attacks, extend to healthcare IoT devices.